

# Information Technology Security Policy v2.5

ACME FINANCIAL SERVICES

INFORMATION TECHNOLOGY SECURITY POLICY

Version 2.5 | Approved: January 2024

Policy Owner: Chief Information Security Officer

## 1. SCOPE

This policy applies to all information systems, networks, and data assets owned or operated by Acme Financial Services.

## 2. ACCESS CONTROL

2.1 Access to systems is granted on a least-privilege basis.

2.2 User accounts are reviewed quarterly by department managers.

2.3 Privileged access accounts require manager approval and are reviewed monthly.

2.4 Passwords must meet complexity requirements: minimum 12 characters, mixed case, numbers, and symbols.

2.5 Shared accounts are prohibited except for designated service accounts.

## 3. ENCRYPTION

3.1 All laptops and mobile devices must use full-disk encryption.

3.2 Customer data stored in databases uses AES-256 encryption.

3.3 Email containing customer PII must be encrypted using approved tools.

## 4. NETWORK SECURITY

4.1 The network is segmented into security zones. Customer data resides in the restricted zone.

4.2 All external-facing systems are protected by web application firewalls (WAF).

4.3 TLS 1.2 is the minimum standard for all encrypted communications. TLS 1.3 is preferred.

4.4 Legacy protocols (SSL, TLS 1.0) are disabled on production systems.

## 5. VULNERABILITY MANAGEMENT

5.1 Vulnerability scans are conducted monthly on all systems.

5.2 Critical vulnerabilities are patched within 7 days of discovery.

5.3 Annual penetration testing is conducted by an approved third-party vendor.

5.4 A bug bounty program covers externally-facing digital products.

## 6. INCIDENT MANAGEMENT

6.1 Security incidents are classified by severity (P1-P4).

6.2 P1 incidents (critical) require immediate escalation to CISO and executive team.

6.3 Incident records are retained for 3 years.

6.4 The CISO reports security posture to the board quarterly.

## 7. THIRD-PARTY SECURITY

7.1 Third-party vendors must complete a security questionnaire before onboarding.

7.2 Vendors with access to production systems must provide SOC 2 Type II reports.

7.3 Cloud service providers must meet FedRAMP Moderate or equivalent certification.

## 8. DATA LOSS PREVENTION

8.1 DLP tools monitor outbound data transfers from corporate systems.

8.2 Transfers of customer PII to personal email or storage are blocked and alerted.

8.3 USB devices are disabled on customer-data-processing workstations.